Deliverable Milestone M3

Matriks Confidence terhadap Otonomi dan Playbook Respons Berjenjang

NIM	2305551076
Nama	Ravi Arnan Irianto
Bidang Keahlian	Network and Cloud Computing
Mata Kuliah	Proyek 1
Milestone	M3 — Penyempurnaan Respons Berjenjang Berbasis Keyakinan (target Oktober 2026)
Judul	Implementasi Sistem SOAR Open-Source Berbasis n8n untuk Deteksi dan Respons Ancaman Malware dan Phishing dengan Mitigasi Aktif Human-in-the-Loop (Studi Kasus: CV Bali Handmade)
Dosen Pembimbing	1. Ir. I Nyoman Piarsa, ST., MT., IPM. 2. A.A. Kt Agung Cahyawan Wiranatha, S.T., M.T.

1. Tujuan

Dokumen ini memuat luaran Milestone M3, yaitu formalisasi aturan pemetaan tingkat keyakinan ancaman terhadap tingkat otonomi tindakan, penyempurnaan jalur human-in-the-loop, serta penerapan batas waktu dan eskalasi ketika analis tidak merespons. Sebelum milestone ini dikerjakan, kebijakan respons masih tersebar pada beberapa node JavaScript dan terdapat tiga kelemahan yang terverifikasi pada sistem live, yaitu jalur persetujuan analis melalui Telegram untuk ancaman malware tidak lagi berfungsi, tidak terdapat mekanisme batas waktu sehingga deteksi yang menunggu keputusan dapat hilang tanpa jejak, serta keputusan analis tidak tersimpan sebagai jejak audit yang terukur.

Seluruh kebijakan pada dokumen ini telah diterapkan pada lingkungan uji dan diverifikasi secara otomatis. Matriks pada Tabel 2 bukan deskripsi rencana, melainkan kontrak kebijakan yang menjadi satu-satunya sumber penentu tindakan otomatis pada sistem.

2. Prinsip Penyusunan

Matriks dan playbook disusun atas empat prinsip yang sejalan dengan arah penelitian, yaitu sebagai berikut.

1. **Berbasis keyakinan (confidence-based).** Tindakan otomatis hanya diberikan kepada deteksi dengan keyakinan tinggi, sedangkan keyakinan sedang diserahkan kepada analis.
2. **Transparan.** Setiap notifikasi menyebut bukti yang mendasarinya sehingga tidak menghasilkan vonis tanpa indikator.
3. **Sadar degradasi (self-aware).** Kegagalan verifikasi dari sumber threat intelligence tidak disenyapkan, melainkan ditandai sebagai belum terverifikasi.
4. **Human-in-the-loop yang dapat dipertanggungjawabkan.** Setiap keputusan analis tercatat lengkap dengan pelaku, waktu, jenis aksi, dan lama waktu respons.

3. Sumber Bukti dan Tingkat Keyakinan

Tingkat keyakinan tidak ditentukan oleh jenis kejadian, melainkan oleh kekuatan bukti yang menyertainya. Sumber bukti yang dipakai beserta sifatnya disajikan pada Tabel 1.

Tabel 1 Sumber bukti dan sifatnya dalam penentuan tingkat keyakinan

Sumber	Bukti yang dibaca	Sifat bukti
VirusTotal	Jumlah deteksi mesin antivirus (malicious, suspicious, undetected)	Kuat bila lima deteksi atau lebih; cache di server dengan masa berlaku berbeda menurut jenis verdict
MalwareBazaar	Signature dan tag keluarga malware	Kuat bila hash terdaftar sebagai malware
AlienVault OTX	Jumlah pulse yang memuat hash	Kuat bila pulse ditemukan; dipakai ketika VirusTotal gagal
MISP (feed OSINT)	Kecocokan hash pada event dan penanda to_ids	Kuat bila hash tercatat pada event
Aturan rantai proses Wazuh	Baris perintah proses dan proses induk (indikasi LOLBin)	Indikatif, karena biner sistem dapat sah

Sumber	Bukti yang dibaca	Sifat bukti
Aturan integritas berkas (FIM)	Perubahan checksum atau kemunculan berkas	Bukan indikator malware; tidak menaikkan tingkat keyakinan
Penanda berkas sistem	Path berkas konfigurasi sistem operasi	Perubahan administratif, dilaporkan tanpa tindakan otomatis
Metadata berkas	Ekstensi berisiko, bit eksekusi, berkas tanpa ekstensi	Sinyal lemah; memerlukan peninjauan analis

4. Matriks Confidence terhadap Otonomi

Pemetaan resmi antara bukti, tingkat keyakinan, tingkat otonomi, tindakan otomatis, dan batas waktu keputusan disajikan pada Tabel 2. Nilai tenggat keputusan hanya berlaku bagi deteksi yang memerlukan persetujuan analis.

Tabel 2 Matriks tingkat keyakinan terhadap tingkat otonomi tindakan

Keyakinan	Bukti pemicu	Tingkat otonomi	Tindakan otomatis	Keputusan analis
Tinggi	Dua puluh deteksi atau lebih; atau signature MalwareBazaar disertai lima deteksi atau lebih	Otonom	Karantina berkas otomatis ditambah notifikasi	Tidak diminta; tersedia tombol penandaan false positive
Tinggi	Lima deteksi atau lebih; atau kecocokan MalwareBazaar, OTX, MISP; atau aturan rantai proses dengan level tinggi	Otonom	Karantina berkas otomatis ditambah notifikasi	Tidak diminta; tersedia tombol penandaan false positive
Sedang	Indikator lemah (satu sampai empat deteksi), verifikasi belum selesai karena kegagalan layanan, atau berkas eksekutabel dengan hash belum dikenal	Human-in-the-loop	Tidak ada tindakan otomatis	Diminta melalui notifikasi bertombol: karantina berkas atau tandai false positive; tenggat 15 menit
Sedang	Rantai proses mencurigakan (indikasi LOLBin)	Human-in-the-loop	Tidak ada tindakan otomatis terhadap biner sistem	Diminta melalui notifikasi bertombol: sudah ditinjau atau tandai false positive; tenggat 15 menit

Keyakinan	Bukti pemicu	Tingkat otonomi	Tindakan otomatis	Keputusan analis
Tidak ada	Perubahan berkas konfigurasi sistem operasi	Ditahan	Tidak ada tindakan otomatis; berkas sistem tidak pernah dikarantina	Dilaporkan dengan tingkat sedang dan VirusTotal dinyatakan tidak relevan
Rendah	Tidak terdapat indikator dari seluruh sumber intelijen	Pemantauan	Tidak ada tindakan otomatis	Tidak diminta; berkas media atau dokumen jinak tidak diberitakan, tetap tercatat pada dasbor

5. Playbook Respons Berjenjang

Setiap tingkat otonomi memiliki langkah baku yang dijalankan sistem, yaitu sebagai berikut.

5.1 Tingkat otonom (keyakinan tinggi)

1. Deteksi masuk melalui webhook, disaring, dan dideduplikasi.
2. Verifikasi berlapis dijalankan pada cache verdict, VirusTotal atau OTX, MalwareBazaar, dan MISP.
3. Kebijakan menetapkan tingkat otonomi otonom sehingga tindakan aktif dijalankan, dengan urutan Wazuh Active Response terlebih dahulu, lalu antrean perintah pada agen ringan apabila Active Response tidak dapat dijalankan.
4. Deteksi tetap didaftarkan pada registri keputusan sebagai jejak audit tanpa tenggat.
5. Notifikasi dikirim memuat bukti deteksi, ringkasan analisis model bahasa, dan tombol penandaan false positive sebagai umpan balik.

5.2 Tingkat human-in-the-loop (keyakinan sedang)

1. Kebijakan menetapkan tingkat otonomi human-in-the-loop sehingga tindakan otomatis dimatikan.
2. Deteksi didaftarkan pada registri keputusan sebelum notifikasi dikirim, memuat hash, agen, path target, tingkat keyakinan, dan batas waktu lima

belas menit.

3. Notifikasi Telegram dikirim dengan tombol tindakan; identitas tombol Membawa pengenal pendek (maksimum enam belas karakter) agar tetap sesuai batas panjang data tombol Telegram.
4. Saat analis menekan tombol, sistem mengklaim keputusan pada registri, mencatat jejak audit, mengambil target tindakan dari registri, menjalankan tindakan aktif hanya untuk aksi karantina, dan memperbarui pesan Telegram.
5. Keputusan juga dikirim ke pemantau fleet sehingga tampil pada dasbor sebagai keputusan analis.
6. Apabila tidak terdapat keputusan sampai batas waktu terlampaui, sistem mengirim eskalasi ke analis dan menandai item tersebut agar tidak dieskalasi berulang.

5.3 Tingkat ditahan dan pemantauan

1. Perubahan berkas konfigurasi sistem dilaporkan dengan tingkat sedang, tanpa tindakan aktif, dan dengan penjelasan bahwa sistem SOAR sendiri menulis entri pemblokiran domain pada berkas tersebut.
2. Deteksi tanpa indikator dicatat pada dasbor tanpa mengganggu analis, kecuali berkas tersebut bukan media atau dokumen jinak.

6. Jaminan Keselamatan Tindakan

Selain matriks, diterapkan lima jaminan agar tindakan otomatis tidak menimbulkan kerugian, yaitu sebagai berikut.

1. Berkas konfigurasi sistem operasi tidak pernah dikarantina, dijaga pada dua lapisan pemeriksaan.
2. Rantai proses tidak pernah dikenai tindakan otomatis, karena biner yang terlibat dapat merupakan biner sistem yang sah.
3. Tindakan aktif hanya dijalankan oleh tingkat otonom dan oleh tombol karantina; aksi penandaan tidak mengeksekusi tindakan aktif.
4. Registri keputusan bersifat gagal-terbuka, sehingga kegagalan registri tidak mematikan fungsi deteksi.

5. Target tindakan diambil dari registri, bukan dari teks pesan, sehingga tetap akurat meskipun pesan Telegram mengalami pemformatan ulang.

7. Jejak Audit, Metrik, dan Bukti Pengujian

Registri keputusan menyediakan jejak audit yang tahan terhadap pemulihan layanan dan metrik waktu respons analis. Data yang terhimpun selama pengujian tanggal 14 Oktober 2026 disajikan pada Tabel 3, sedangkan ringkasan pengujian disajikan pada Tabel 4.

Tabel 3 Data registri keputusan setelah pengujian live tanggal 14 Oktober 2026

Metrik registri	Nilai	Keterangan
Total deteksi tercatat	7	Tiga di antaranya berasal dari pengujian otomatis berulang
Keputusan selesai	3	Dua karantina dan satu penandaan selesai ditinjau
Deteksi jalur human-in-the-loop	5	Dua di antaranya dieskalasi karena melewati tenggat
Deteksi jalur otonom	2	Tidak menunggu keputusan, tetap tercatat untuk audit
Rata-rata waktu respons analis	5,3 detik	Nilai maksimum 8 detik pada lingkungan pengujian

Tabel 4 Ringkasan pengujian matriks confidence terhadap otonomi

Lapisan pengujian	Hasil	Cakupan
Uji unit registri keputusan dan eskalasi	58 dari 58 lulus	Validasi masukan, tenggat, eskalasi satu kali, jejak audit, persistensi lintas pemulihan, masa berlaku, dan token opsional
Uji unit kebijakan dan jalur callback	26 dari 26 lulus	Pemetaan tiap tingkat keyakinan, muatan pendaftaran, pembacaan tombol, pemilihan tindakan aktif, dan penyaring eskalasi
Pengujian end-to-end pada sistem live	36 dari 36 lulus	Jalur human-in-the-loop tanpa tindakan otomatis, keputusan analis melalui tombol, jalur otonom dengan tindakan aktif, dan eskalasi batas waktu
Pengujian idempotensi penerapan	Penerapan kedua tanpa perubahan	Penerapan kebijakan dapat diulang tanpa menggandakan node maupun koneksi

8. Batasan dan Rencana Lanjutan

Beberapa batasan berikut dicatat secara terbuka sebagai dasar pengembangan berikutnya, yaitu sebagai berikut.

1. Jalur phishing belum menggunakan registri keputusan sehingga target tindakannya masih dibaca dari teks pesan.
2. Jalur otonom baru menyediakan umpan balik penandaan false positive, belum menyediakan pembatalan karantina.
3. Pembatasan akses pada layanan registri keputusan belum diaktifkan dan direncanakan menjadi bagian pengerasan keamanan pada milestone berikutnya.
4. Batas waktu lima belas menit dan masa berlaku enam jam masih seragam untuk semua tingkat keyakinan.
5. Pengukuran waktu respons analis masih berasal dari pengujian berukuran sampel kecil sehingga perlu dilanjutkan dengan jumlah pengulangan minimal tiga puluh pada milestone pengujian kuantitatif.

Denpasar, 14 Oktober 2026

Mahasiswa,

Ravi Arnan Irianto
NIM 2305551076